

Tema 7

Esquema nacional de seguridad

1. Introducción	2
2. Origen del ENS	3
3. Esquema nacional de seguridad	4
4. Principios básicos de ENS	14
5. REQUISITOS MÍNIMOS DE SEGURIDAD	18
6. COMUNICACIONES ELECTRÓNICAS.....	25

1. Introducción

“Si usted cree que la tecnología puede resolver sus problemas de seguridad, entonces ni entiende usted los problemas ni entiende la tecnología.” (*Bruce Schneier*)

“Las organizaciones gastan millones de dólares en firewalls y dispositivos de seguridad, pero tiran el dinero porque ninguna de estas medidas cubre el eslabón más débil de la cadena de seguridad: la gente que usa y administra los ordenadores” (*Kevin Mitnick*)

Es necesaria una estrategia de seguridad

- **Ley 11/2007, de 22 de Junio, de acceso electrónico de los ciudadanos a los Servicios Públicos (LAECSP)**

Permite :

- Garantizar la provisión de servicios de las AAPP hacia los ciudadanos por medios telemáticos y electrónicos
- Mejorar las condiciones actuales en la prestación de esos mismos servicios en su modalidad presencial.

- **El Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad (ENS)**

Permite :

- Garantizar la provisión de servicios de las AAPP hacia los ciudadanos por medios telemáticos y electrónicos
- Mejorar las condiciones actuales en la prestación de esos mismos servicios en su modalidad presencial.

El Esquema Nacional de Seguridad o también conocido por las siglas E-N-S tiene su origen en la **Ley de acceso electrónico de los ciudadanos a los Servicios Públicos**. El objetivo de esta ley es garantizar que las Administraciones Públicas proveen por medios electrónicos sus servicios con las mismas garantías que cuando estos son prestados de forma presencial.

Para ello, impulsado por la **Ley de acceso electrónico de los ciudadanos a los Servicios Públicos**, se desarrolla el **Real Decreto 3/2010**, donde se da forma a los **principios y requisitos mínimos de seguridad** que se deben cumplir para garantizar el cumplimiento de lo dispuesto en dicha Ley.

2. Origen del ENS

ENS como complemento de LAECSP

- **Visión desde la Ley Acceso Electrónico (LAECSP)**

- **Dar servicio de puertas afuera:**

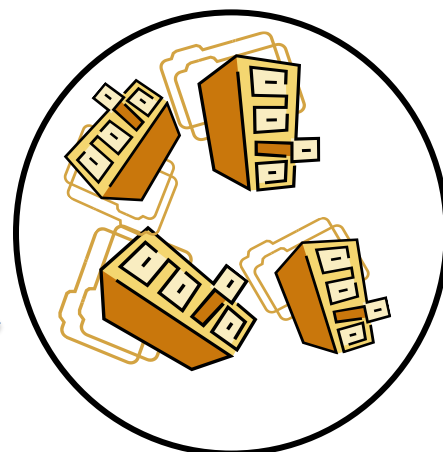
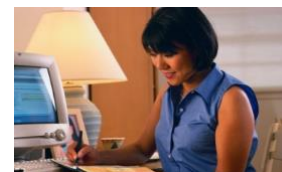
- Actuación no presencial :
 - Internet / Intranet

- **Visión desde la Ley del ENS**

- **Puertas adentro: reorganización interna**

- Reingeniería de procesos
 - Cambios en aplicaciones informáticas

Nuevos hábitos en SEGURIDAD



La Ley 11/2007, de 22 de junio, posibilita e inspira el Esquema Nacional de Seguridad, en los aspectos de la seguridad de los sistemas de tecnologías de la información en las Administraciones públicas, contribuyendo al desarrollo de un instrumento efectivo que permite garantizar los derechos de los ciudadanos en la Administración electrónica.

3. Esquema nacional de seguridad

El ENS establece los principios y requisitos de una política de seguridad que permita la adecuada protección de la información en la utilización de los medios electrónicos en el acceso de los ciudadanos a los Servicios Públicos.

La finalidad del Esquema Nacional de Seguridad es la creación de confianza en el uso de los medios electrónicos, a través de medidas para garantizar la seguridad de los sistemas, los datos, las comunicaciones, y los servicios electrónicos, en el acceso de los ciudadanos a los Servicios Públicos.

Los **objetivos** del ENS son:

- Crear las **condiciones necesarias de confianza** en el uso de los medios electrónicos, que permita a los ciudadanos y a las administraciones públicas, el ejercicio de **derechos** y el cumplimiento de **deberes** a través de estos medios.
- Introducir los elementos comunes que han de guiar la actuación de las administraciones públicas en **materia de seguridad** de las tecnologías de la información.

Según el ENS:

- La seguridad ha de ser un proceso integral, cuya gestión ha de estar basada en riesgos y se deben contemplar los aspectos de prevención, reacción y recuperación.
- La estrategia de protección ha de estar constituida por múltiples capas de seguridad y las medidas de seguridad deben ser reevaluadas y actualizadas periódicamente.
- Para ello, define auditorías de seguridad con una periodicidad mínima de 2 años.

Quién debe cumplir el ENS?

- **AAPP, incluidas las siguientes entidades:**
 - Administración General del Estado.
 - Las Administraciones de las Comunidades Autónomas.
 - Las entidades que integran la Administración Local.
 - Las entidades de derecho público pertenecientes al sector público institucional.
 - Entidades de derecho privado pertenecientes al sector público institucional.
 - Entidades de derecho privado vinculadas o dependientes de las comunidades autónomas.
 - Entidades de derecho privado vinculadas o dependientes de la administración de las entidades locales.
 - Universidades públicas.
 - Corporaciones de derecho público.
 - Órganos constitucionales y órganos legislativos y de control autonómicos.
 - Entidades de derecho privado y fundaciones.
- **EMPRESAS DEL SECTOR PRIVADO:**
 - Proporcionan soluciones tecnológicas o servicios comprendidos dentro del ámbito objetivo de aplicación del Esquema Nacional de Seguridad.

¿Quién debe cumplir el ENS?

El Esquema Nacional de Seguridad, será de aplicación:

Primero, a las entidades de derecho privado vinculadas o dependientes de las Comunidades Autónomas cuando ejerzan potestades administrativas por atribución directa o delegación, de acuerdo a la legislación autonómica aplicable, así como en cuanto a su régimen de patrimonio y en materia de responsabilidad patrimonial ante terceros por

el funcionamiento de sus servicios, cuando se rijan por las previsiones de la Ley 39/2015, de 1 de octubre, de Procedimiento Administrativo Común de las Administraciones Públicas en los términos establecidos por esta.

Segundo, a las entidades de derecho privado vinculadas o dependientes de la Administración de las Entidades Locales en las materias en que les sea de aplicación la normativa presupuestaria, contable, de control financiero, de control de eficacia y contratación, de acuerdo a lo dispuesto por la Ley 7/1985, de 2 de abril, Reguladora de las Bases del Régimen Local, así como en el ejercicio de las funciones públicas que les hayan sido atribuidas estatutariamente, cuando se rijan por las previsiones de la Ley 39/2015, de 1 de octubre, de Procedimiento Administrativo Común de las Administraciones Públicas en los términos establecidos por esta.

También será de aplicación, a las corporaciones de derecho público en el ejercicio de las funciones públicas que les hayan sido atribuidas por Ley o delegadas por una Administración Pública, cuando se rijan por las previsiones de la Ley 39/2015, de 1 de octubre, de Procedimiento Administrativo Común de las Administraciones Públicas en los términos establecidos por esta, de forma supletoria a su normativa específica.

Las empresas privadas deberán proporcionar soluciones o servicios, en los términos establecidos en la Declaración o Certificación de Conformidad con el ENS, utilizando los criterios y procedimientos previstos en la Guía CCN-STIC-809 "Declaración y Certificación de Conformidad con el ENS y Distintivos de Cumplimiento".

Definido en : GUÍA DE SEGURIDAD (CCN-STIC-830) **ÁMBITO DE APLICACIÓN DEL ESQUEMA NACIONAL DE SEGURIDAD**

Ejemplos: abrir guía por la pagina 8

Modelo declaración conformidad con el ENS y distintivo



Modelo de certificación conformidad con el ENS y distintivo



A efectos de dar cumplimiento a lo dispuesto en el artículo 41 del ENS, los Distintivos referidos a las Declaraciones de Conformidad con el ENS que se exhibirán en la sede electrónica del organismo en cuestión, poseerán el aspecto y contenido que se muestra en la figura.

Modelos de certificación de conformidad y distintivos.

A efectos de dar cumplimiento a lo dispuesto en el artículo 41 del ENS, los Distintivos de Conformidad referidos a las Certificaciones de Conformidad con el ENS, que se exhibirán en la sede electrónica del organismo en cuestión, poseerán el aspecto y contenido que se muestra en la figura siguiente, incluyendo la categoría del sistema certificado, BÁSICA, MEDIA o ALTA.

¿CUÁL ES EL ÁMBITO DE APLICACIÓN DEL ENS?

- La LAECSP regula los aspectos básicos de la utilización de las tecnologías de la información en tres ámbitos:
 - **La actividad Administrativa.**
 - **Las relaciones entre las AAPP.**
 - **Las relaciones de los ciudadanos con las AAPP.**
- Por tanto, el ENS **tendrá aplicación sobre estas actividades y los activos involucrados en ejecutarlas.**
- **Excluidas** las actividades que las AAPP lleven a cabo en régimen de derecho privado o que no estuvieren dedicados a gestionar las funciones o competencias propias de la entidad pública de que se trate.

El Esquema Nacional de Seguridad está constituido por los principios básicos y requisitos mínimos requeridos para una protección adecuada de la información. Será aplicado por las Administraciones Públicas para asegurar el acceso, integridad, disponibilidad, autenticidad, confidencialidad, trazabilidad y conservación de los datos, informaciones y servicios utilizados en medios electrónicos que gestionen en el ejercicio de sus competencias.”

Por tanto, es de aplicación en todas y cada una de las actuaciones de las entidades públicas del ámbito subjetivo de aplicación del ENS **que desarrollen o contribuyan a desarrollar el Procedimiento Administrativo.**

¿QUÉ SISTEMAS DEBEN CUMPLIR EL ENS?

- Según la Guía CCN-STIC-830 Ámbito Aplicación ENS sería de aplicación en todo lo relativo a:
 - Facilitar a los ciudadanos a relacionarse electrónicamente con las AAPP.
 - Facilitar por medios electrónicos en el Procedimiento Administrativo.
 - Facilitar el uso de medios de identificación y firma electrónica a los interesados.
 - Registros electrónicos.
 - Archivos electrónicos

- Funcionamiento electrónico de las administraciones.

La seguridad se entenderá como un proceso integral constituido por **todos los elementos técnicos, humanos, materiales y organizativos, relacionados con el sistema**. La aplicación del ENS estará presidida por este principio, que excluye cualquier actuación puntual o tratamiento coyuntural.

Por tanto, el ENS se aplica esencialmente a los sistemas de información **que soportan la actividad administrativa, la actividad interadministrativa y las relaciones con los ciudadanos**.

EJEMPLOS:

ARCHIVO ELECTRÓNICO	GESTIÓN VACANTES HOSPITAL	GESTIÓN EXPEDIENTES ACADÉMICOS
CITAS OBTENCIÓN DNI	PROCEDIMIENTOS SANCIONADORES	PADRÓN AYUNTAMIENTO
PERFIL CONTRATANTE	GESTIÓN CONTABILIDAD	GESTIÓN RRHH
TRAMITACIÓN LEGISLATIVA	GESTIÓN TRIBUTARIA	SISTEMAS SCADA

A continuación, se presentan algunos ejemplos de los sistemas que deben cumplir el ENS.

El **Archivo electrónico** de los procedimientos administrativos desarrollados, por ser un sistema de información para el desarrollo del procedimiento administrativo de la entidad.

El sistema de gestión de **vacantes de un hospital** público, por ser un sistema de información para el cumplimiento de deberes del hospital.

La gestión de los **expedientes académicos** de los alumnos de una Universidad pública, por ser un sistema de información para el desarrollo de las funciones competenciales de la Universidad.

La gestión de las **citas para la obtención del DNI**, por ser un sistema de información para el cumplimiento de deberes de los ciudadanos.

La gestión de los **procedimientos sancionadores**, por ser un sistema de información para el desarrollo del procedimiento administrativo de la entidad.

La gestión del **padrón de un Ayuntamiento**, por ser un sistema de información para el desarrollo de las funciones competenciales del Ayuntamiento.

El **perfil del contratante**, por ser un sistema de información accesible electrónicamente por las empresas para el ejercicio de derechos.

La gestión de la **contabilidad**, por ser un sistema de información para el cumplimiento de deberes de la entidad.

La gestión de **recursos humanos**, por ser un sistema de información para el ejercicio de derechos de los empleados.

La **tramitación legislativa**, por ser un sistema de información para el desarrollo de las funciones competenciales de la entidad.

La **gestión tributaria**, por ser un sistema de información para el desarrollo de las funciones competenciales de la entidad.

Sistemas SCADA, cuando son propiedad de cualquiera de las entidades del Sector Público.

No obstante lo anterior, por los importantes beneficios que se derivan de ello, siempre **resulta conveniente aplicar el ENS a todos los sistemas de las entidades**, incluso los que contenga información de transparencia o pública excluida de toda confidencialidad, toda vez que constituye la herramienta más adecuada para preservar las debidas garantías dimensiones que estos necesitan tales como la disponibilidad, integridad, trazabilidad y autenticidad que la actuación de cualquier entidad del sector público requiere.

¿QUÉ SISTEMAS QUEDAN EXCLUIDOS?

Los sistemas no relacionados con el ejercicio de derechos (interesados, ciudadanos, empleados), ni con el cumplimiento de deberes por medios electrónicos, ni con el acceso por medios electrónicos de los ciudadanos a la información y al procedimiento administrativo, de acuerdo con lo previsto en la Ley 11/2007, de 22 de junio, Ley 39/2015 y Ley 40/2015.

¿QUÉ HACER PARA CUMPLIR CON ENS?

Para abordar el proyecto de adecuación al ENS, se deberá aplicar una metodología que considere los siguientes pasos:

1. Establecer una política de seguridad.
2. Identificar los sistemas afectados.
3. Determinar los riesgos sobre los sistemas afectados.
4. Categorizar los sistemas afectados.
5. Insuficiencias del sistema.
6. Aplicar los controles correspondientes, de los previstos en el Anexo II del ENS.

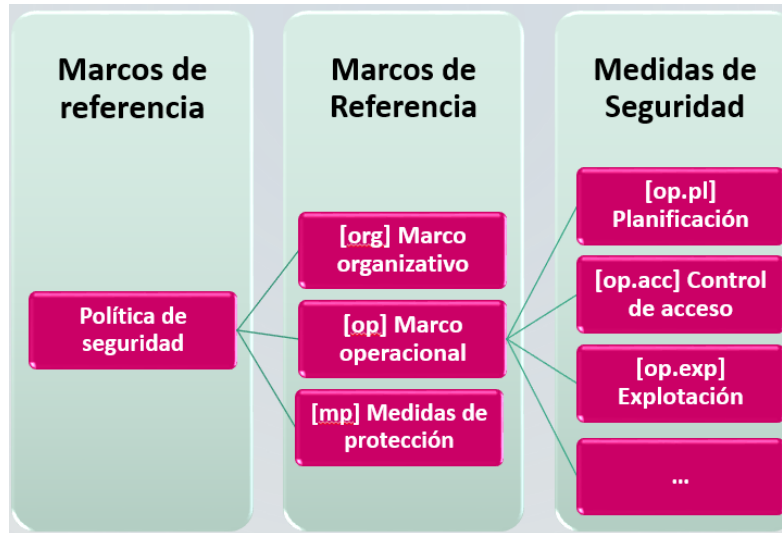
La disposición transitoria del Real Decreto 3/2010, articula el siguiente mecanismo escalonado para la adecuación a lo previsto en el ENS:

- Los sistemas de las administraciones deberán estar adecuados a este Esquema en el plazo de doce meses, aunque si hubiese circunstancias que impidan la plena aplicación, se **dispondrá de un plan de adecuación que marque los plazos de ejecución**, en ningún caso superiores a 48 meses desde la entrada en vigor.
- El primer plazo de 12 meses se cumplió el **29 de enero de 2011** y el segundo plazo de 48 meses se cumplió el **29 de enero de 2014**.

El citado **plan de adecuación** será elaborado por el Responsable de Seguridad del sistema, deberá estar aprobado por los órganos superiores competentes y contendrá la siguiente información:

- La política de seguridad
- Información que se maneja, con su valoración.
- Servicios que se prestan, con su valoración.
- Datos de carácter personal.
- Categoría del sistema.
- Declaración de aplicabilidad de las medidas del Anexo II del ENS.
- Análisis de riesgos
- Insuficiencias del sistema.
- Plan de mejora de seguridad, incluyendo plazos estimados de ejecución.

CONTROLES PREVISTOS EN EL ANEXO II



Marco organizativo [org]. Constituido por el conjunto de medidas relacionadas con la organización global de la seguridad. (4 controles).

Marco operacional [op]. Formado por las medidas a tomar para proteger la operación del sistema como conjunto integral de componentes para un fin. (36 controles).

Medidas de protección [mp]. Se centran en proteger activos concretos, según su naturaleza y la calidad exigida por el nivel de seguridad de las dimensiones afectadas. (40 controles).

NECESIDAD DE UN SGSI

El SGSI se exige en diversos puntos de la norma:

- 4.1.2 Arquitectura de seguridad [op.pl.2].
 - La seguridad del sistema será objeto de un planteamiento integral detallando, al menos, los siguientes aspectos:
 - f) Sistema de gestión con actualización y aprobación periódica.
- ANEXO III: Auditoría de la seguridad
 - f) Que existe un sistema de gestión de la seguridad de la información, documentado y con un proceso regular de aprobación por la dirección.

El ENS contempla y exige la gestión continuada de la seguridad en diversos puntos de la norma, para lo cual cabe aplicar un sistema de gestión.

Un Sistema de gestión de la seguridad de la información (SGSI), es un Sistema de gestión que, basado en el estudio de los riesgos, que se establece para crear, implementar, hacer funcionar, supervisar, revisar, mantener y mejorar la seguridad de la información. El sistema de gestión incluye la estructura organizativa, las políticas, las actividades de planificación, las responsabilidades, las prácticas, los procedimientos, los procesos y los recursos.

Los tipos de pruebas de auditoría: son evaluación del ciclo de madurez del SGSI auditado, criterios para la revisión y agenda de mejoras.

- Guía CCN-STIC 802

25. Documentación mínima para planificar la auditoría:

Descripción detallada del sistema de gestión de la seguridad y la documentación que lo sustancia.

30. Elementos a incluir en la auditoría:

Los procesos de mejora continua de la seguridad.

4. Principios básicos de ENS

• **Artículo 5: Principios Básicos del ENS:**

- a) Seguridad integral.
- b) Gestión de riesgos.
- c) Prevención, reacción y recuperación.
- d) Líneas de defensa.
- e) Reevaluación periódica.
- f) Función diferenciada.

Artículo 5. Principios Básicos del ENS:

El objeto último de la seguridad de la información es asegurar que una organización administrativa podrá cumplir sus objetivos utilizando sistemas de información. En las decisiones en materia de seguridad deberán tenerse en cuenta los siguientes principios básicos:

- a) Seguridad integral.
- b) Gestión de riesgos.
- c) Prevención, reacción y recuperación.
- d) Líneas de defensa.
- e) Reevaluación periódica.
- f) Función diferenciada.

Artículo 6. La seguridad como un proceso integral.

- Constituido por todos los elementos técnicos, humanos, materiales y organizativos, relacionados con el sistema.
- Concienciación de las personas

Artículo 6. La seguridad como un proceso integral.

- La seguridad se entenderá como un proceso integral constituido por todos los elementos técnicos, humanos, materiales y organizativos, relacionados con el sistema. La aplicación del Esquema Nacional de Seguridad estará presidida por este principio, que excluye cualquier actuación puntual o tratamiento coyuntural.

- Se prestará la máxima atención a la concienciación de las personas que intervienen en el proceso y a sus responsables jerárquicos, para que, ni la ignorancia, ni la falta de organización y coordinación, ni instrucciones inadecuadas, sean fuentes de riesgo para la seguridad.

Artículo 7. Gestión de la seguridad basada en los riesgos.

- El análisis y gestión de riesgos permanentemente actualizado.
- Mantenimiento de un entorno controlado, minimizando los riesgos hasta niveles aceptables.

Artículo 7. Gestión de la seguridad basada en los riesgos.

1. El análisis y gestión de riesgos será parte esencial del proceso de seguridad y deberá mantenerse permanentemente actualizado.
2. La gestión de riesgos permitirá el mantenimiento de un entorno controlado, minimizando los riesgos hasta niveles aceptables. La reducción de estos niveles se realizará mediante el despliegue de medidas de seguridad, que establecerá un equilibrio entre la naturaleza de los datos y los tratamientos, los riesgos a los que estén expuestos y las medidas de seguridad.

Artículo 8. Prevención, reacción y recuperación.

- Prevención: eliminar o reducir la posibilidad de amenazas
 - la disuasión y la reducción de la exposición.
- Detección y reacción, incidentes de seguridad se atajen a tiempo.
- Recuperación: restauración de la información y los servicios
- Garantía de conservación de los datos e informaciones en soporte electrónico.

Artículo 8. Prevención, reacción y recuperación.

1. La seguridad del sistema debe contemplar los aspectos de prevención, detección y corrección, para conseguir que las amenazas sobre el mismo no se materialicen, no afecten gravemente a la información que maneja, o los servicios que se prestan.
2. Las medidas de prevención deben eliminar o, al menos reducir, la posibilidad de que las amenazas lleguen a materializarse con perjuicio para el sistema. Estas medidas de prevención contemplarán, entre otras, la disuasión y la reducción de la exposición.
3. Las medidas de detección estarán acompañadas de medidas de reacción, de forma que los incidentes de seguridad se atajen a tiempo.

4. Las medidas de recuperación permitirán la restauración de la información y los servicios, de forma que se pueda hacer frente a las situaciones en las que un incidente de seguridad inhabilite los medios habituales.

5. Sin merma de los demás principios básicos y requisitos mínimos establecidos, el sistema garantizará la conservación de los datos e informaciones en soporte electrónico.

De igual modo, el sistema mantendrá disponibles los servicios durante todo el ciclo vital de la información digital, a través de una concepción y procedimientos que sean la base para la preservación del patrimonio digital.

- **Artículo 9. Líneas de defensa.**

- Estrategia de protección → múltiples capas de seguridad
 - Si una falla:
 - a) Ganar tiempo para una reacción adecuada.
 - b) Reducir la probabilidad de que el sistema sea comprometido.
 - c) Minimizar el impacto final sobre el mismo.
- Las líneas de defensa han de estar constituidas por medidas de naturaleza organizativa, física y lógica.

Artículo 9. Líneas de defensa.

1. El sistema ha de disponer de una estrategia de protección constituida por múltiples capas de seguridad, dispuesta de forma que, cuando una de las capas falle, permita:

- a) Ganar tiempo para una reacción adecuada frente a los incidentes que no han podido evitarse.
- b) Reducir la probabilidad de que el sistema sea comprometido en su conjunto.
- c) Minimizar el impacto final sobre el mismo.

2. Las líneas de defensa han de estar constituidas por medidas de naturaleza organizativa, física y lógica.

- **Artículo 10. Reevaluación periódica.**

Artículo 10. Reevaluación periódica.

Las medidas de seguridad se reevaluarán y actualizarán periódicamente, para adecuar su eficacia a la constante evolución de los riesgos y sistemas de protección, llegando incluso a un replanteamiento de la seguridad, si fuese necesario.

• **Artículo 11. La seguridad como función diferenciada.**

- Diferenciado el responsable de la información, del servicio y de la seguridad.
- Seguridad de sistemas de Información <> de prestación de servicios.
- La política de seguridad de la organización
 - Atribuciones de cada responsable
 - Mecanismos de coordinación y resolución de conflictos.

Artículo 11. La seguridad como función diferenciada.

En los sistemas de información se diferenciará el responsable de la información, el responsable del servicio y el responsable de la seguridad.

El responsable de la información determinará los requisitos de la información tratada; el responsable del servicio determinará los requisitos de los servicios prestados; y el responsable de seguridad determinará las decisiones para satisfacer los requisitos de seguridad de la información y de los servicios.

La responsabilidad de la seguridad de los sistemas de información estará diferenciada de la responsabilidad sobre la prestación de los servicios.

La política de seguridad de la organización detallará las atribuciones de cada responsable y los mecanismos de coordinación y resolución de conflictos.

Artículo 12. Requisitos mínimos de seguridad.

• Obligatoriedad de **Política de seguridad:**

- a) Organización e implantación del proceso de seguridad.
- b) Análisis y gestión de los riesgos.
- c) Gestión de personal.
- d) Profesionalidad.
- e) Autorización y control de los accesos.
- f) Protección de las instalaciones.
- g) Adquisición de productos.
- h) Seguridad por defecto.
- i) Integridad y actualización del sistema.
- j) Protección de la información almacenada y en tránsito.
- k) Prevención ante otros sistemas de información interconectados.
- l) Registro de actividad.
- m) Incidentes de seguridad.

Artículo 12. Requisitos mínimos de seguridad.

Todos los órganos superiores de las Administraciones públicas deberán disponer formalmente de su política de seguridad, que será aprobada por el titular del órgano

superior correspondiente. Esta política de seguridad, se establecerá en base a los principios básicos indicados y se desarrollará aplicando los siguientes requisitos mínimos:

- a) Organización e implantación del proceso de seguridad.
- b) Análisis y gestión de los riesgos.
- c) Gestión de personal.
- d) Profesionalidad.
- e) Autorización y control de los accesos.
- f) Protección de las instalaciones.
- g) Adquisición de productos.
- h) Seguridad por defecto.
- i) Integridad y actualización del sistema.
- j) Protección de la información almacenada y en tránsito.
- k) Prevención ante otros sistemas de información interconectados.

5. REQUISITOS MÍNIMOS DE SEGURIDAD

- **Artículo 12. Organización e implantación del proceso de seguridad**
 - Seguridad aplicable a todos los miembros de la organización

Artículo 12. Organización e implantación del proceso de seguridad.

La seguridad deberá comprometer a todos los miembros de la organización. La política de seguridad según se detalla en el anexo II, deberá identificar unos claros responsables de velar por su cumplimiento y ser conocida por todos los miembros de la organización administrativa.

- **Artículo 13. Análisis y gestión de los riesgos**
 - Realización de un análisis y tratamientos del sistema según una metodología conocida.
Ej.: Magerit

Artículo 13. Análisis y gestión de los riesgos.

1. Cada organización que desarrolle e implante sistemas para el tratamiento de la información y las comunicaciones realizará su propia gestión de riesgos.

2. Esta gestión se realizará por medio del análisis y tratamiento de los riesgos a los que está expuesto el sistema. Sin perjuicio de lo dispuesto en el anexo II, se empleará alguna metodología reconocida internacionalmente.

3. Las medidas adoptadas para mitigar o suprimir los riesgos deberán estar justificadas y, en todo caso, existirá una proporcionalidad entre ellas y los riesgos.

• **Artículo 14. Gestión de personal.**

- Personal Información y Sistemas formado.
- El significado y alcance del uso seguro → normativa de seguridad
- Cada usuario identificado de forma única: Autenticidad y trazabilidad

Artículo 14. Gestión de personal.

1. Todo el personal relacionado con la información y los sistemas deberá ser formado e informado de sus deberes y obligaciones en materia de seguridad. Sus actuaciones deben ser supervisadas para verificar que se siguen los procedimientos establecidos.

2. El personal relacionado con la información y los sistemas, ejercerá y aplicará los principios de seguridad en el desempeño de su cometido.

3. El significado y alcance del uso seguro del sistema se concretará y plasmará en unas normas de seguridad.

4. Para corregir, o exigir responsabilidades en su caso, cada usuario que acceda a la información del sistema debe estar identificado de forma única, de modo que se sepa, en todo momento, quién recibe derechos de acceso, de qué tipo son éstos, y quién ha realizado determinada actividad.

• **Artículo 15. Profesionalidad.**

- Seguridad gestionada → personal cualificado.
- Exigencia a empresas proveedoras de seguridad de profesionales cualificados.

Artículo 15. Profesionalidad.

1. La seguridad de los sistemas estará atendida, revisada y auditada por personal cualificado, dedicado e instruido en todas las fases de su ciclo de vida: instalación, mantenimiento, gestión de incidencias y desmantelamiento.

2. El personal de las Administraciones públicas recibirá la formación específica necesaria para garantizar la seguridad de las tecnologías de la información aplicables a los sistemas y servicios de la Administración.

Las Administraciones públicas exigirán, de manera objetiva y no discriminatoria, que las organizaciones que les presten servicios de seguridad cuenten con profesionales cualificados y con unos niveles idóneos de gestión y madurez en los servicios prestados.»

- **Artículo 16. Autorización y control de accesos**

- Acceso a los SI controlados y limitados a usuarios permitidos.

Artículo 16. Autorización y control de los accesos.

El acceso al sistema de información deberá ser controlado y limitado a los usuarios, procesos, dispositivos y otros sistemas de información, debidamente autorizados, restringiendo el acceso a las funciones permitidas.

- **Artículo 17. Protección de las instalaciones**

- Áreas separadas para los SI, cerradas y con control de acceso.

Artículo 17. Protección de las instalaciones.

Los sistemas se instalarán en áreas separadas, dotadas de un procedimiento de control de acceso. Como mínimo, las salas deben estar cerradas y disponer de un control de llaves.

- **Artículo 18. Adquisición de productos de seguridad y contratación de servicios de seguridad**

- Adquisición de productos de seguridad según categorización del sistema y nivel de seguridad determinados.

1. En la adquisición de productos de seguridad de las tecnologías de la información y comunicaciones que vayan a ser empleados por las Administraciones públicas se utilizarán, de forma proporcionada a la categoría del sistema y nivel de seguridad determinados, aquellos que tengan certificada la funcionalidad de seguridad relacionada con el objeto de su adquisición, salvo en aquellos casos en que las exigencias de proporcionalidad en cuanto a los riesgos asumidos no lo justifiquen a juicio del responsable de seguridad.

- **Artículo 19. Seguridad por defecto.**

- El sistema proporcionará la funcionalidad mínima requerida para alcanzar los objetivos de la organización.
- En explotación se desactivarán por “control de la configuración” las funciones innecesarias
- El uso ha de ser sencillo y seguro, una utilización insegura requiera de un acto consciente

Artículo 19. Seguridad por defecto.

Los sistemas deben diseñarse y configurarse de forma que garanticen la seguridad por defecto:

- a) El sistema proporcionará la mínima funcionalidad requerida para que la organización alcance sus objetivos.
- b) Las funciones de operación, administración y registro de actividad serán las mínimas, y se asegurará que sólo son accesibles por las personas, o desde emplazamientos o equipos, autorizados, pudiendo exigirse en su caso restricciones de horario y puntos de acceso facultados.
- c) En un sistema de explotación se eliminarán o desactivarán, mediante el control de la configuración, las funciones que no sean de interés, sean innecesarias e, incluso, aquellas que sean inadecuadas al fin que se persigue.
- d) El uso ordinario del sistema ha de ser sencillo y seguro, de forma que una utilización insegura requiera de un acto consciente por parte del usuario.

- **Artículo 20. Integridad y actualización del sistema**

- Conocer el estado de seguridad de los sistemas.

Artículo 20. Integridad y actualización del sistema.

1. Todo elemento físico o lógico requerirá autorización formal previa a su instalación en el sistema.
2. Se deberá conocer en todo momento el estado de seguridad de los sistemas, en relación a las especificaciones de los fabricantes, a las vulnerabilidades y a las actualizaciones

- **Artículo 21. Protección de la información almacenada y en tránsito**
 - Prestar especial atención a información almacenada.

Artículo 21. Protección de información almacenada y en tránsito.

1. En la estructura y organización de la seguridad del sistema, se prestará especial atención a la información almacenada o en tránsito a través de entornos inseguros. Tendrán la consideración de entornos inseguros los equipos portátiles, asistentes personales (PDA), dispositivos periféricos, soportes de información y comunicaciones sobre redes abiertas o con cifrado débil.

- **Artículo 22. Prevención ante otros sistemas de información interconectados.**
 - Protección del perímetro del SI, sobretodo si está interconectado a redes públicas.

Artículo 22. Prevención ante otros sistemas de información interconectados.

El sistema ha de proteger el perímetro, en particular, si se conecta a redes públicas. En todo caso se analizarán los riesgos derivados de la interconexión del sistema, a través de redes, con otros sistemas, y se controlará su punto de unión.

- **Artículo 23. Registro de actividad.**
 - Registro de las actividades para monitorizar, analizar, investigar y documentar actividades indebidas o no autorizadas.

Artículo 23. Registro de actividad.

Con la finalidad exclusiva de lograr el cumplimiento del objeto del presente real decreto, con plenas garantías del derecho al honor, a la intimidad personal y familiar y a la propia imagen de los afectados, y de acuerdo con la normativa sobre protección de datos personales, de función pública o laboral, y demás disposiciones que resulten de aplicación, se registrarán las actividades de los

usuarios, reteniendo la información necesaria para monitorizar, analizar, investigar y documentar actividades indebidas o no autorizadas, permitiendo identificar en cada momento a la persona que actúa.

- **Artículo 24. Incidentes de seguridad.**

- Se establecerá un sistema de detección y reacción frente a código dañino.
- Se dispondrá de un procedimiento de gestión de incidentes de seguridad y debilidades detectadas en los SI.

Artículo 24. Incidentes de seguridad.

1. Se establecerá un sistema de detección y reacción frente a código dañino.
2. Se dispondrá de procedimientos de gestión de incidentes de seguridad y de debilidades detectadas en los elementos del sistema de información. Estos procedimientos cubrirán los mecanismos de detección, los criterios de clasificación, los procedimientos de análisis y resolución, así como los cauces de comunicación a las partes interesadas y el registro de las actuaciones. Este registro se empleará para la mejora continua de la seguridad del sistema.

- **Artículo 25. Continuidad de la actividad.**

- Copias de seguridad y mecanismos para garantizar la continuidad de las operaciones

Artículo 25. Continuidad de la actividad.

Los sistemas dispondrán de copias de seguridad y establecerán los mecanismos necesarios para garantizar la continuidad de las operaciones, en caso de pérdida de los medios habituales de trabajo.

- **Artículo 26. Mejora continua del proceso de seguridad.**

- Criterios y métodos nacional e internacional relativos a gestión de las tecnologías de la información.

Artículo 26. Mejora continua del proceso de seguridad.

El proceso integral de seguridad implantado deberá ser actualizado y mejorado de forma continua. Para ello, se aplicarán los criterios y métodos reconocidos en la práctica nacional e internacional relativos a gestión de las tecnologías de la información.

- **Artículo 27. Cumplimiento requisitos mínimos**

- Redacción “Declaración de Aplicabilidad” de las medidas seleccionadas del Anexo II
- Declaración firmada por el responsable de seguridad

Artículo 27. Cumplimiento de requisitos mínimos.

1. Para dar cumplimiento a los requisitos mínimos establecidos en el presente real decreto, las Administraciones públicas aplicarán las medidas de seguridad indicadas en el Anexo II.

4. La relación de medidas seleccionadas del Anexo II se formalizará en un documento denominado Declaración de Aplicabilidad, firmado por el responsable de seguridad.

- **Artículo 28. Infraestructuras y servicios comunes**

- Determinados por cada administración

Artículo 28. Infraestructuras y servicios comunes.

La utilización de infraestructuras y servicios comunes reconocidos en las Administraciones Públicas facilitará el cumplimiento de los principios básicos y los requisitos mínimos exigidos en el presente real decreto en condiciones de mejor eficiencia. Los supuestos concretos de utilización de estas infraestructuras y servicios comunes serán determinados por cada Administración.

- **Artículo 29. Instrucciones técnicas de seguridad y guías de seguridad.**

- El Centro Criptológico Nacional elabora guías de seguridad TIC de consulta.

Para el mejor cumplimiento de lo establecido en el Esquema Nacional de Seguridad, el Centro Criptológico Nacional, en el ejercicio de sus competencias, elaborará y difundirá las correspondientes guías de seguridad de las tecnologías de la información y las comunicaciones.

3. Las instrucciones técnicas de seguridad tendrán en cuenta las normas armonizadas a nivel europeo que resulten de aplicación.»

- **Artículo 30. Sistemas de información no afectados.**

- Si no permite el ejercicio de derechos ni con el cumplimiento de deberes por medios electrónicos
- Si no facilita el acceso por medios electrónicos de los ciudadanos a la información y al procedimiento administrativo

Artículo 30. Sistemas de información no afectados.

Las Administraciones públicas podrán determinar aquellos sistemas de información a los que no les sea de aplicación lo dispuesto en el presente de real decreto por tratarse de sistemas no relacionados con el ejercicio de derechos ni con el cumplimiento de deberes por medios electrónicos ni con el acceso por medios electrónicos de los ciudadanos a la información y al procedimiento administrativo, de acuerdo con lo previsto en la Ley 11/2007, de 22 de junio.

6. COMUNICACIONES ELECTRÓNICAS

- **Artículo 31. Condiciones técnicas de seguridad de las comunicaciones electrónicas.**

- Constancia de
 - la transmisión y recepción,
 - de sus fechas,
 - del contenido íntegro de las comunicaciones
 - y la identificación fidedigna del remitente y destinatario de las mismas.

Artículo 31. Condiciones técnicas de seguridad de las comunicaciones electrónicas.

1. Las condiciones técnicas de seguridad de las comunicaciones electrónicas en lo relativo a la constancia de la transmisión y recepción, de sus fechas, del contenido íntegro de las comunicaciones y la identificación fidedigna del remitente y destinatario de las mismas, según lo establecido en la Ley 11/2007, de 22 de junio, serán implementadas de acuerdo con lo establecido en el Esquema Nacional de Seguridad.

• Artículo 32. Requerimientos técnicos de notificaciones y publicaciones electrónicas.

- Aseguren la autenticidad del organismo que lo publique.
- Aseguren la integridad de la información publicada.
- Dejen constancia de la fecha y hora de la puesta a disposición del interesado y del acceso a su contenido.
- Aseguren la autenticidad del destinatario de la publicación o notificación.

Artículo 32. Requerimientos técnicos de notificaciones y publicaciones electrónicas.

1. Las notificaciones y publicaciones electrónicas de resoluciones y actos administrativos se realizarán de forma que cumplan, de acuerdo con lo establecido en el presente real decreto, las siguientes exigencias técnicas:

- a) Aseguren la autenticidad del organismo que lo publique.
- b) Aseguren la integridad de la información publicada.
- c) Dejen constancia de la fecha y hora de la puesta a disposición del interesado de la resolución o acto objeto de publicación o notificación, así como del acceso a su contenido.
- d) Aseguren la autenticidad del destinatario de la publicación o notificación.

• Artículo 33. Firma electrónica.

Artículo 33. Firma electrónica.

1. Los mecanismos de firma electrónica se aplicarán en los términos indicados en el Anexo II de la norma y de acuerdo con lo preceptuado en la política de firma electrónica y de certificados, según se establece en el Esquema Nacional de Interoperabilidad.

2. La política de firma electrónica y de certificados concretará los procesos de generación, validación y conservación de firmas electrónicas, así como las características y requisitos exigibles a los sistemas de firma electrónica, los certificados, los servicios de sellado de tiempo, y otros elementos de soporte de las firmas, sin perjuicio de lo previsto en el Anexo II, que deberá adaptarse a cada circunstancia.

Artículo 34. Auditoría de la seguridad

- Sistemas de información deberán realizar una auditoría (al menos cada 2 años) de verificación de cumplimientos de los requerimientos del ENS
- En función de la categoría del sistema

Artículo 34. Auditoría de la seguridad.

1. Los sistemas de información a los que se refiere el presente real decreto serán objeto de una auditoría regular ordinaria, al menos cada dos años, que verifique el cumplimiento de los requerimientos del presente Esquema Nacional de Seguridad.

Esta auditoría se realizará en función de la categoría del sistema, determinada según lo dispuesto en el anexo I y de acuerdo con lo previsto en el anexo III.

En el marco de lo dispuesto en el artículo 39, de la ley 11/2007, de 22 de junio, la auditoría profundizará en los detalles del sistema hasta el nivel que considere que proporciona evidencia suficiente y relevante, dentro del alcance establecido para la auditoría.

Los informes de auditoría serán presentados al responsable del sistema y al responsable de seguridad competentes. Estos informes serán analizados por este último que presentará sus conclusiones al responsable del sistema para que adopte las medidas correctoras adecuadas.